# IR Triage Report

## Front Matter

**ANALYST NAME:** Craig Yuzon
**DATE:** April 28, 2026
**SOURCE:** Splunk: index=client1
**ALERT ID:** UR-INT-20250603-0047
**SEVERITY:** CRITICAL
**DISPOSITION:** True Positive (TP)

## Initial Findings

This alert flagged what appeared to be suspicious web traffic targeting a public-facing web server. Upon investigation, the activity turned out to be a multi-stage attack carried out by a known APT group called Po1s0n1vy, which involved web application scanning, brute-force login attempts, website defacement, and ransomware deployment.
The scope of this incident was wide. It affected a public-facing web server, an internal workstation used by a standard domain user, and a network file server. The attacker was able to move laterally from the workstation to the file server using SMB, and a total of 658 files were encrypted across both systems. This wasn't just one device — the attacker had a foothold across multiple parts of the network.
I dispositioned this as a True Positive (TP) — Escalated because the evidence was clear and consistent across multiple log sources. Network traffic logs, IDS alerts, Sysmon process logs, and Windows Registry data all told the same story. The attacker's IP addresses, domain names, and file hashes also matched known threat intelligence tied to the Po1s0n1vy APT group, which gave me high confidence that this was real malicious activity and not a false alarm.
I assessed the severity as CRITICAL because ransomware was actually detonated, files were encrypted, a website was defaced, and the attacker moved across multiple systems inside the network. This isn't something that can wait — it needs immediate escalation to L2/L3 and an incident response team needs to be involved right away.

## Incident Summary

Total Time Range and Duration
Incident activity was observed between 2016-08-10 21:45:00 UTC and 2016-08-24 17:15:12 UTC, spanning approximately 14 days from initial scanning to full ransomware detonation.

**Timeline of Key Events (UTC)**
**2016-08-10 21:45:00 UTC:** Attacker IP 40.80.148.42 began automated web application scanning against imreallynotbatman.com using Acunetix vulnerability scanner.
**2016-08-10 21:45:21 UTC:** Brute force login attempts began against the Joomla administrator login page from attacker IP 23.22.63.114 using a Python-based scripting tool.
**2016-08-10 21:48:05 UTC:** Attacker successfully authenticated to the Joomla admin panel using the password "batman."
**2016-08-10 21:51:35 UTC:** Compromised web server began making outbound requests to attacker-controlled infrastructure, fetching the defacement image poisonivy-is-coming-for-you-batman.jpeg from 23.22.63.114.
**2016-08-10 21:52:00 UTC:** Website defacement confirmed — attacker replaced site content using the fetched image.
**2016-08-10 22:00:00 UTC:** Malicious executable 3791.exe uploaded to the web server via HTTP POST request from attacker IP.

**2016-08-10 22:00:21 UTC**: 3791.exe executed on the web server via cmd.exe.
**2016-08-24 16:48:12 UTC:** Workstation we8105desk (192.168.250.100) performed DNS lookup to solidaritedeproximite.org — a compromised website used as a malware distribution point.
**2016-08-24 16:48:13 UTC**: Workstation downloaded mhtr.jpg from 37.187.37.150 — a steganographically encoded file containing the Cerber ransomware cryptor.
**2016-08-24 16:48:21 UTC:** VBScript 20429.vbs executed via wscript.exe, which launched the Cerber payload 121214.tmp from the user's AppData\Roaming directory.
**2016-08-24 16:49:24 UTC:** Workstation queried ipinfo.io — consistent with Cerber ransomware checking the victim's public IP address.
**2016-08-24 17:15:12 UTC:** Workstation made DNS lookup to Cerber C2 domain cerberhhyed5frqa.xmfir0.win, confirming active ransomware communication.
**2016-08-24 17:15:00 UTC** onwards: Cerber ransomware began encrypting files on the local workstation and spread laterally via SMB to the file server at 192.168.250.20.

**Scope**
The following assets were confirmed affected:
192.168.250.70 — Public-facing Joomla web server (imreallynotbatman.com). Exploited via vulnerability scanning and brute force. Admin credentials compromised, site defaced, and malicious executable uploaded and run.
we8105desk (192.168.250.100) — Internal Windows workstation belonging to domain user bob.smith.WAYNECORPINC. Infected by Cerber ransomware via malicious VBScript dropper. 401 unique .txt files encrypted.
192.168.250.20 — Internal file server. Reached via SMB lateral movement from the infected workstation. 257 unique PDF files encrypted on we9041srv.
USB device MIRANDA_PRI — Physical removable media connected to we8105desk, potentially used as part of the initial infection vector.

**Impact**
The impact of this incident was significant across multiple systems:
The public-facing website imreallynotbatman.com was defaced by the Po1s0n1vy APT group.
Administrative credentials to the Joomla CMS were compromised through brute force.
A total of 658 files were encrypted by Cerber ransomware across the internal workstation and file server — 401 .txt files and 257 .pdf files respectively.
Malicious executable 3791.exe (MD5: AAE3F5A29935E6ABCC2C2754D12A9AF0) was successfully deployed and executed on the web server.
The attacker established communication with external C2 infrastructure at cerberhhyed5frqa.xmfir0.win.
No confirmed data exfiltration was observed during the investigation window, however the full extent of data access cannot be ruled out given the level of attacker access achieved.

The following **MITRE ATT&CK** techniques were observed:

**Exploit Public-Facing Application (T1190):** Acunetix vulnerability scanner used to identify and exploit weaknesses in the public-facing Joomla web server.
**Brute Force (T1110):** 412 unique passwords attempted against the Joomla administrator login page from attacker IP 23.22.63.114 using a Python-based scripting tool.
**Defacement: External Defacement (T1491.002):** Public-facing website imreallynotbatman.com replaced with attacker-controlled image poisonivy-is-coming-for-you-batman.jpeg.
**Command and Scripting Interpreter: Visual Basic (T1059.005):** VBScript file 20429.vbs executed via wscript.exe to download and launch the Cerber ransomware payload.
**Obfuscated Files or Information: Steganography (T1027.003):** Cerber cryptor hidden inside mhtr.jpg using steganography to evade detection.

**Remote Services: SMB/Windows Admin Shares (T1021.002):** Cerber ransomware spread laterally from we8105desk to file server 192.168.250.20 via SMB.
**Data Encrypted for Impact (T1486):** Cerber ransomware encrypted 658 files across the internal workstation and network file server.
**Replication Through Removable Media (T1091)**: USB device MIRANDA_PRI connected to infected workstation we8105desk.

**Threat Intelligence Indicators**
The following indicators of compromise were identified during this investigation:
**IP Addresses**
**40.80.148.42 —** Attacker scanning IP running Acunetix WVS 10.0 Free Edition against imreallynotbatman.com.
**23.22.63.114** — Pre-staging server hosted on AWS (AS14618) used to deliver the defacement image and conduct brute force login attempts against the Joomla admin panel.
**37.187.37.150** — OVH-hosted server (AS16276, France) used to serve mhtr.jpg containing the steganographically embedded Cerber cryptor.

**Domains and FQDNs**
**prankglassinebracket.jumpingcrab.com** — Dynamic DNS FQDN tied to attacker pre-staging infrastructure.
**po1s0n1vy.com** — Primary domain associated with the threat actor. Historical WHOIS records confirm registrant as Lillian Rose, Toxicodendron Inc.
**solidaritedeproximite.org** — Compromised legitimate French website used as a Cerber ransomware distribution point.
**cerberhhyed5frqa.xmfir0.win** — Cerber ransomware command and control domain contacted by infected workstation we8105desk.

**Email Address**
**lillian@po1s0n1vy.com** — Registrant email address confirmed via Whoxy historical WHOIS lookup dated July 24, 2016.

**File Hashes**
**AAE3F5A29935E6ABCC2C2754D12A9AF0 (MD5)** — Hash of malicious executable 3791.exe uploaded to and executed on the Joomla web server.
**9709473ab351387aab9e816eff3910b9f28a7a70202e250ed46dba8f820f34a8 (SHA256)** — Hash of **MirandaTateScreensaver.scr.exe,** a spear phishing payload linked to the Po1s0n1vy APT group's infrastructure and flagged by 50/72 vendors on VirusTotal.

**Filenames**
**poisonivy-is-coming-for-you-batman.jpeg** — Defacement image fetched from attacker-controlled infrastructure and used to deface imreallynotbatman.com.
**mhtr.jpg** — JPEG file containing steganographically embedded Cerber ransomware cryptor, downloaded from 37.187.37.150.
**20429.vbs** — VBScript dropper executed on we8105desk via wscript.exe, responsible for downloading and launching the Cerber payload.
**121214.tmp** — Cerber ransomware payload executed from C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming.
**3791.exe** — Malicious executable uploaded to the Joomla web server via HTTP POST and executed via cmd.exe.
**MirandaTateScreensaver.scr.exe** — APT-linked spear phishing malware associated with Po1s0n1vy infrastructure.

Hardware
**MIRANDA_PRI** — USB removable media device connected to infected workstation we8105desk during the incident window.

**Threat Actor**
**Po1s0n1vy APT group** — A known threat actor with a consistent Batman/DC Comics themed attack infrastructure. Attribution is based on WHOIS registration data linking po1s0n1vy.com to Lillian Rose and Toxicodendron Inc., confirmed malicious domains resolving to attacker-controlled IPs, and malware samples flagged across multiple threat intelligence platforms. For further reference see Malpedia and MITRE ATT&CK Groups.

# Recommended Actions

**IR-Related Actions for Impacted Infrastructure**

- Immediately isolate we8105desk (192.168.250.100) from the network to prevent further ransomware spread or attacker communication. Notify the asset owner and escalate to L2/L3 for forensic imaging before any remediation begins.
- Take the Joomla web server (192.168.250.70) offline or isolate it from public access while IR team assesses the full extent of the compromise. The web server had a malicious executable uploaded and executed — it should be treated as fully compromised.
- Isolate file server 192.168.250.20 from the network immediately. Cerber ransomware reached this server via SMB lateral movement and encrypted 257 PDF files. The IR team should assess whether additional files beyond PDFs were affected.
- Identify and preserve all encrypted files on both we8105desk and the file server for potential decryption. Do not attempt to restore from backup until the ransomware has been fully eradicated from all affected systems.
- Revoke and reset all credentials associated with the compromised Joomla admin account. The password "batman" was brute forced — all admin accounts on the web server should be considered compromised.
- Review the USB device MIRANDA_PRI — determine who connected it to we8105desk, when, and what files it may have contained. This device should be seized and examined by the IR team.
- Notify relevant stakeholders including management and legal/compliance teams given the confirmed ransomware detonation and potential data destruction across multiple systems.

**Prevention-Related Recommended Actions for Impacted Infrastructure**

- Patch and harden the Joomla CMS installation immediately. Implement account lockout policies on the admin login page to prevent future brute force attempts. Consider restricting admin panel access to internal IPs only.
- Block the following IPs at the perimeter firewall: 40.80.148.42, 23.22.63.114, and 37.187.37.150. Add the following domains to the DNS blocklist: po1s0n1vy.com, solidaritedeproximite.org, cerberhhyed5frqa.xmfir0.win, and prankglassinebracket.jumpingcrab.com.
- Implement multi-factor authentication (MFA) on the Joomla admin panel and all other externally accessible web applications to prevent credential-based attacks from succeeding even if passwords are compromised.
- Restrict SMB traffic between workstations and file servers using firewall rules and network segmentation. Workstations should not have unrestricted SMB access to file servers — this allowed Cerber to spread laterally.
- Implement application whitelisting on endpoints to prevent unauthorized executables like 121214.tmp and 3791.exe from running. Specifically restrict execution of files from %APPDATA% directories.
- Disable or restrict wscript.exe and cscript.exe on endpoints where VBScript execution is not required for business operations. This would have blocked the 20429.vbs dropper from executing.
- Enforce a USB device control policy that restricts unauthorized removable media from being connected to corporate endpoints. The MIRANDA_PRI USB device should not have been able to connect without authorization.

**Prevention-Related Recommended Actions for Internal Policies**

- Enforce a strong password policy across all systems — particularly for web application admin accounts. Passwords like "batman" should be rejected by policy. Minimum length, complexity requirements, and regular rotation should be mandated.
- Implement a security awareness training program for all staff covering phishing, social engineering, and safe browsing habits. The initial infection of we8105desk began with a user visiting a malicious website — user education could have prevented this.

- Establish a clear removable media policy that prohibits use of unauthorized USB devices on corporate endpoints. All removable media should be scanned before use and approved by IT.
- Review and enforce the principle of least privilege across all systems. Standard domain users like bob.smith.WAYNECORPINC should not have permissions that allow ransomware to encrypt files on network file servers.
- Develop and document an incident response playbook specifically for ransomware events that includes isolation steps, backup restoration procedures, and communication protocols for legal and management notification.

**Detection-Related Recommended Actions for Improved SOC Flows**

- Tune Suricata IDS rules to alert on connections to dynamic DNS providers like jumpingcrab.com and unusual TLDs like .win — these are commonly used by attackers for C2 infrastructure.
- Implement a detection rule that correlates a high volume of HTTP POST requests to a login page with a successful login from the same IP within a short time window. This would have flagged the brute force attack against Joomla earlier.
- Add detection coverage for files with non-executable extensions (such as .jpg) being downloaded and immediately followed by script execution events. The mhtr.jpg → 20429.vbs → 121214.tmp chain should trigger an alert.
- Implement behavioral detection for wscript.exe spawning child processes or making outbound network connections — this is highly suspicious behavior and was a key step in the Cerber infection chain.
- Enhance DNS monitoring to alert on lookups to newly registered domains, domains with high entropy subdomains, or domains with unusual TLDs like .win and .bit — consistent with DGA behavior used by Cerber.
- Update the SOC's IR playbook for web application attacks to include steps for checking stream:http for file uploads via POST requests, specifically looking at the part_filename{} field for executable file uploads.
- Consider implementing a threat intelligence feed that automatically blocks known malicious IPs and domains associated with active ransomware campaigns — this could have blocked connections to solidaritedeproximite.org and cerberhhyed5frqa.xmfir0.win before the infection took hold.